

ABC Healthcare Services

INCIDENT RESPONSE POLICY

Information Security Governance Program

Field	Details
Document ID	IRP-001
Version	1.0
Classification	Internal
Policy Owner	Information Security Manager
Approved By	Executive Management
Effective Date	June 1, 2026

Document Revision History

Version	Date	Description	Author
1.0	June 1, 2026	Initial Release	Information Security Manager

1. Purpose

The purpose of this Incident Response Policy is to establish a structured and consistent approach for identifying, reporting, investigating, responding to, containing, eradicating, and recovering from information security incidents. Effective incident management minimizes business disruption, reduces financial and reputational damage, and supports regulatory and compliance requirements.

Risk Statement

Failure to properly manage information security incidents may result in data breaches, operational disruption, financial losses, legal liabilities, regulatory penalties, and reputational damage.

2. Scope

This policy applies to all employees, contractors, consultants, vendors, third-party service providers, temporary personnel, and authorized users of ABC Healthcare Services information systems. The policy applies to security incidents involving applications, databases, endpoints, cloud services, networks, physical devices, and organizational information assets.

3. Policy Objectives

- Establish a standardized incident response process.
- Minimize business impact resulting from security incidents.
- Protect the confidentiality, integrity, and availability of information.
- Ensure timely incident reporting and escalation.
- Support compliance, legal, and audit requirements.
- Promote continuous improvement through lessons learned activities.
- Strengthen organizational cyber resilience.

4. Security Incident Categories

Critical Severity Incident

Examples:

- Ransomware attack
- Major data breach
- Complete system outage
- Privileged account compromise

Response Target: 15 Minutes

High Severity Incident

Examples:

- Malware infection
- Unauthorized system access
- Credential compromise
- Insider threat investigation

Response Target: 1 Hour

Medium Severity Incident

Examples:

- Phishing attacks
- Policy violations
- Suspicious network activity
- Abnormal login behaviour

Response Target: 4 Hours

Low Severity Incident

Examples:

- Spam emails
- Minor configuration issues
- Non-malicious user errors

Response Target: 1 Business Day

5. Incident Reporting Requirements

All personnel must immediately report:

- Suspected security breaches
- Phishing emails
- Lost or stolen devices
- Malware infections
- Unauthorized access attempts
- Data leakage incidents
- Policy violations

Reporting Channels

Method	Contact
Email	security@abchealthcare.com
Help Desk	Internal Service Desk
Hotline	Security Operations Team

6. Incident Response Lifecycle

Phase 1 – Identification

Activities include:

- Security monitoring
- Alert investigation
- Event analysis
- Incident validation

Phase 2 – Containment

Activities include:

- Isolating affected systems
- Blocking malicious activity
- Preserving evidence
- Limiting business impact

Phase 3 – Eradication

Activities include:

- Malware removal
- Vulnerability remediation
- System cleanup
- Security control improvements

Phase 4 – Recovery

Activities include:

- Restoring systems
- Validation testing
- Business resumption
- User communications

Phase 5 – Lessons Learned

Activities include:

- Root cause analysis
- Risk assessment review
- Documentation updates
- Control improvements

7. Roles and Responsibilities

Role	Responsibility
Executive Management	Strategic oversight and approvals
Information Security Manager	Incident coordination
IT Team	Investigation and remediation
Department Managers	Business coordination
Employees	Incident reporting
Third-Party Vendors	Incident notifications and support

8. Evidence Handling

Security incidents often require the preservation of evidence to support investigations, litigation, regulatory reporting, and forensic analysis.

Examples of evidence include:

- System logs
- Network logs
- Security alerts
- Screenshots
- Email records
- Audit logs

Evidence Requirements

- Evidence must be preserved.
- Evidence must not be altered.
- Chain of custody records must be maintained.
- Access to evidence shall be restricted.
- Evidence shall be retained according to legal and regulatory requirements.

9. Communication Requirements

Internal Communication

Security incidents shall be communicated to:

- Information Security Team
- Executive Management
- Department Managers
- Relevant Business Units

External Communication

Where appropriate:

- Customers
- Regulators
- Law Enforcement
- Business Partners
- Third-Party Vendors

All external communications require management approval.

10. Third-Party Incident Management

Third-party incidents involving organizational systems or information must be reported within **24 Hours**

Vendors must cooperate with investigations and provide relevant incident details, remediation plans, and evidence when requested.

11. Compliance Monitoring

Key Performance Indicators (KPIs)

Metric	Target
Critical Incident Response Time	15 Minutes
Incident Closure Rate	95%
Security Awareness Completion	100%
Lessons Learned Reviews	100%
Incident Documentation Accuracy	100%
Incident Escalation Compliance	100%

Sample Compliance Dashboard

Control	Result
Critical Response SLA	100%
Incident Closure Rate	96%
Security Training Completion	98%
Lessons Learned Reviews	100%
Escalation Compliance	100%

12. Policy Violations

Failure to comply with this policy may result in:

- Verbal warning
- Written warning
- Suspension of privileges
- Disciplinary action
- Employment termination
- Legal action where appropriate

All violations shall be investigated by the Information Security Team.

13. Policy Exceptions

Requests for policy exceptions must include:

- Business justification
- Risk assessment
- Management approval
- Information Security approval
- Compensating controls
- Defined expiration date

All approved exceptions shall be documented and reviewed annually.

14. Conclusion

ABC Healthcare Services is committed to maintaining an effective incident response capability to protect information assets, support business operations, and reduce organizational risk. Through timely detection, response, containment, recovery, and continuous improvement activities, the organization strengthens its overall security posture and resilience against cyber threats.

15. References

- ISO/IEC 27001:2022
- NIST Cybersecurity Framework
- NIST Incident Response Guidelines
- CIS Critical Security Controls
- Information Security Governance Framework

16. Document Control

Field	Value
Document Owner	Information Security Manager
Document ID	IRP-001
Version	1.0
Classification	Internal
Review Frequency	Annual
Next Review Date	June 1, 2027